ONE-PAGE BRIEF

Post-quantum cryptography review: rage @ b5b68c4f4f7e

Client: str4d (rage / age encryption) — public repository (passive review) · Source: github.com/str4d/rage, commit `b5b68c4f4f7e` · Reviewed: 2026-11-06 13:47 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
Level 1 of 4
post-quantum code present, not wired

FINDINGS
2 Critical **4** High **5** Medium
17 Low **3** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Key establishment: 10 + 5 − 8 = 7 → **too late**
Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Wire the existing post-quantum primitive into a critical path (key wrapping or the channel) behind a hybrid construction, and test interoperability.

WHAT MATTERS MOST

Critical QSI-2026-18619	**zip 8.6.0 is affected by GHSA-m665-v7pm-7grj (CVE-2026-115905)** What to do: Upgrade to a fixed version (9.0.5).
Critical QSI-2026-18623	**zip 8.6.0 is affected by RUSTSEC-2026-0369** What to do: Upgrade to a fixed version (9.0.0).
High QSI-2026-18617	**zip 8.6.0 is affected by GHSA-9hj8-73fh-9963 (CVE-2026-115907)** What to do: Upgrade to a fixed version (9.0.0).
High QSI-2026-18618	**zip 8.6.0 is affected by GHSA-hjqx-j4rw-g7xv (CVE-2026-115908)** What to do: Upgrade to a fixed version (9.0.0).

24 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium key wrapping and data encryption at rest	X25519	Wrap keys with ML-KEM or a hybrid KEM (X25519 + ML-KEM-768) and re-wrap the stored keys; data that may…
Medium authentication and identity (certificates, tokens, device attestation)	RSA	Keep credentials short-lived and plan ML-DSA certificates, tokens and keys as the ecosystem supports them
Medium role not determined	X25519	Classify each usage, record data lifetimes, and plan migration to Hybrid key establishment with ML-KEM (FIPS…

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 25; unlikely to apply to this build: 13 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 12.

Static review of source code and manifests; files analysed: 54. No requests were sent to the owner's systems.

Full report, content SHA-256: `dbd2c6df52207712f1309e15dc6cc70cdf4862fa5fc16ef83f11ff9fb2c78d1b`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.